

DevSecOps 3-4-Mothers-Secret

Mother's Secret: Exploit flaws found in Mother's code to reveal its secrets.

In this challenge, you will investigate the TryHackMe Cargo Star Ship (THMCSS) Nostromo, owned by the Weyland-TryHackMe Corps and its compromised computer system, MU-TH-UR 6000. Your mission is to uncover hidden secrets by exploiting vulnerabilities in the web application running on the Nostromo server. Get ready to put your code analysis and exploitation skills to the test!

Setting Up:

1. Start the AttackBox.
2. Start the Lab Machine provided for this challenge and note the Machine's IP address; you will need it later to access the web app.
3. You can now open the AttackBox and enter the MU-TH-UR 6000 server's IP address in the browser running on port 80.

Upon accessing the MU-TH-UR6000 computer, AKA Mother, you will see the Mother UI server. However, since you only have a "Crew" Member level role, you only have read access to limited resources. But there are other ways to access it. Can you find them and uncover Mother's secret?

Equipment Check: Download the files attached to this task to review the code.

1. Explore the available endpoints of the Mother Server and try to find any clues that can reveal mother's secret.
2. Search for a file that contains essential information about the ship's activities.
3. Exploit the vulnerable code to download the secrets from the server. Can you spot the vulnerable code?
4. Capture all the hidden flags you encounter during your exploration. Only Mother holds this secret.

Operating Manual: Below are some sequences and operations to get you started. Use the following to unlock information and navigate Mother:

- Emergency command override is 100375. Use it when accessing *Alien Loaders*.
- Download the task files to learn about Mother's routes.
- Hitting the *routes* in the *right* order makes Mother confused, it might think you are a Science Officer!

I used **yaml.js** and **nostromo.js** from the GitHub repository *Scientistz/mothersSecret*.

The process starts with **YAML**, followed by **nostromo.js**, which sends a POST request. After accessing the `/nostromo` endpoint and setting `isNostromoAuthenticate = true`, the user is authenticated. If the authentication check passes, the application returns the answers.

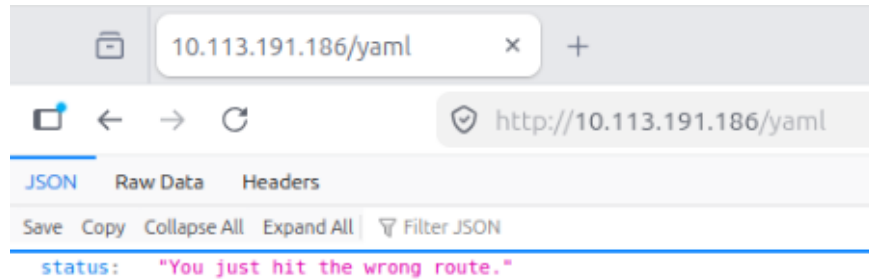
```
fs.readFile(filePath, "utf8", (err, data) => {
  if (err) {
    res.status(500).json({
      status: "error",
      message: "Science Officer Eyes Only",
    });
    return;
  }
})
```

The application contains three endpoints:

- `/yaml`
- `/nostromo`
- `/nostromo/mother`

The analysis began by examining the `/yaml` endpoint. After reviewing the code, I used **yaml.js** and **nostromo.js** from the GitHub repository *Scientistz/mothersSecret* to understand how the application processes requests.

The `/nostromo` endpoint handles POST requests. During the code review, I identified the `isNostromoAuthenticate` variable. When this value is set to `true`, the user is successfully authenticated. After authentication succeeds, access to the `/nostromo/mother` endpoint reveals the answers.



From source

```

1 <!DOCTYPE html>
2 <html lang="en">
3 <head>
4 <meta charset="UTF-8" />
5 <meta http-equiv="X-UA-Compatible" content="IE=edge" />
6 <meta name="viewport" content="width=device-width, initial-scale=1.0" />
7 <link rel="stylesheet" href="/style/style.css" />
8 <script src="https://cdn.tailwindcss.com"></script>
9 <script
10 src="https://kit.fontawesome.com/4f572bc49d.js"
11 crossorigin="anonymous"
12 ></script>
13 <title>Mothers Secret</title>
14 </head>
15 <body class="body">
16 <div class="wrapper flex flex-col overflow-hidden max-h-screen relative">
17 <div
18 class="crew-member absolute top-10 left-50% bg-black px-3 py-1 rounded text-xl font-bold text-center whitespace-nowrap w-[8.6rem]"
19 style="z-index: 100"
20 >
21 Crew Member
22 </div>
23 <div
24 class="overflow-hidden w-full h-full bg-[#ab964d] z-10 p-2 dots-container"
25 ></div>
26 </div>
27 <script src="https://cdn.socket.io/4.4.1/socket.io.min.js"></script>
28 <script src="/index.min.js"></script>
29 </body>
30 </html>
31

```

I investigated the page source, followed the URL referenced in the source code, and analyzed the JavaScript files. Using jsbeautifier.org to deobfuscate and format the code, I was able to identify the application's endpoints and understand the authentication logic.



Can you guess what is `/api/nostromo/mother/secret.txt`?

St...	Method	Domain	File	Initiator	Ty...	Size	Response
304	GET	10.113.191.186	/	document	ht...	1.0...	HTML
304	GET	10.113.191.186	style.css	stylesheet	css	4.4...	
302	GET	cdn.tailwindcss.com	/	script	js	0 B	
200	GET	kit.fontawesome.com	4f572bc49d.js	script	js	6.1...	FOR SCIENCE OFFICER EYES ONLY special SECRETS: REROUTING TO: api/nostromo ORDER: 0rd3r937.txt [****] UNABLE TO CLARIFY. NO FURTHER ENHANCEMENT.
200	GET	cdn.socket.io	socket.io.min.js	script	js	0 B	
304	GET	10.113.191.186	index.min.js	script	js	8.4...	
200	GET	fonts.googleapis.com	css?family=Source+Sans+Pro&family=Ubuntu	stylesheet	css	-1 B	
200	GET	cdn.tailwindcss.com	3.4.17	script	js	407...	
200	GET	kit.fontawesome.com	free.min.css?token=4f572bc49d	css	css	73...	
200	GET	kit.fontawesome.com	free-v4-shims.min.css?token=4f572bc49d	css	css	21...	
200	GET	kit.fontawesome.com	free-v5-font-face.min.css?token=4f572bc49d	css	css	823 B	
200	GET	kit.fontawesome.com	free-v4-font-face.min.css?token=4f572bc49d	css	css	1.7...	
200	GET	10.113.191.186	/socket.io/EIO=4&transport=polling&?PyNPXHQ	socket.io	pl...	28...	118 B
200	GET	10.113.191.186	/socket.io/EIO=4&transport=polling&?PyNPXHS	socket.io	pl...	28...	118 B
200	POST	10.113.191.186	/socket.io/EIO=4&transport=polling&?PyNPXHSid=g_Rw	socket.io	ht...	14...	2 B
200	GET	10.113.191.186	favicon.ico	img	json	42 B	
200	GET	10.113.191.186	/socket.io/EIO=4&transport=polling&?PyNPX3&sid=g_Rv	socket.io	pl...	20...	38 B
200	POST	10.113.191.186	/socket.io/EIO=4&transport=polling&?PyNPXW&sid=e9V	socket.io	ht...	14...	2 B
200	GET	10.113.191.186	/socket.io/EIO=4&transport=polling&?PyNPXje&sid=e9M	socket.io	pl...	20...	38 B
101	GET	10.113.191.186	/socket.io/EIO=4&transport=websocket&sid=g_RvOxFWRI	socket.io	pl...	12...	0 B
200	POST	10.113.191.186	/socket.io/EIO=4&transport=polling&?PyNPXm&sid=g_Ri	socket.io	ht...	14...	2 B
101	GET	10.113.191.186	/socket.io/EIO=4&transport=websocket&sid=e9Mr9Awqm	socket.io	pl...	12...	0 B
200	GET	10.113.191.186	/socket.io/EIO=4&transport=polling&?PyNPXmT&sid=g_Ri	socket.io	pl...	20...	42 B
200	GET	10.113.191.186	/socket.io/EIO=4&transport=polling&?PyNPXm&sid=e9V	socket.io	pl...	16...	1 B
200	GET	10.113.191.186	/socket.io/EIO=4&transport=polling&?PyNPXm&sid=g_Ri	socket.io	pl...	16...	1 B
200	POST	10.113.191.186	yaml	xhr	ht...	39...	145 B

Answer the questions below

What is the number of the emergency command override?

100375

Operating Manual

Below are some sequences and operations to get you started. Use the following to unlock information and navigate Mother:

- Emergency command override is 100375. Use it when accessing *Alien Loaders*.
- Download the task files to learn about Mother's routes.
- Hitting the *routes* in the *right* order makes Mother confused, it might think you are a Science Officer!

Can you guess what is `/api/nostromo/mother/secret.txt`?

What is the special order number?

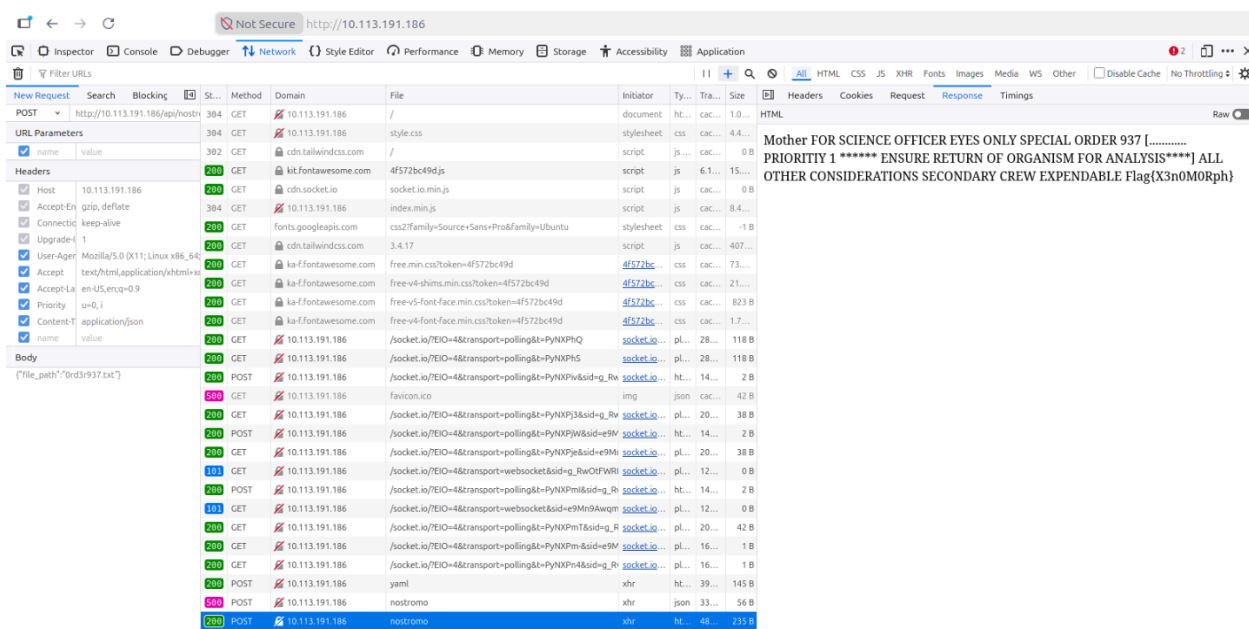
937

After investigating the page source and reviewing the Network tab, I identified a POST request being sent to the `/api/nostromo` endpoint.

To replicate the request, I configured the following:

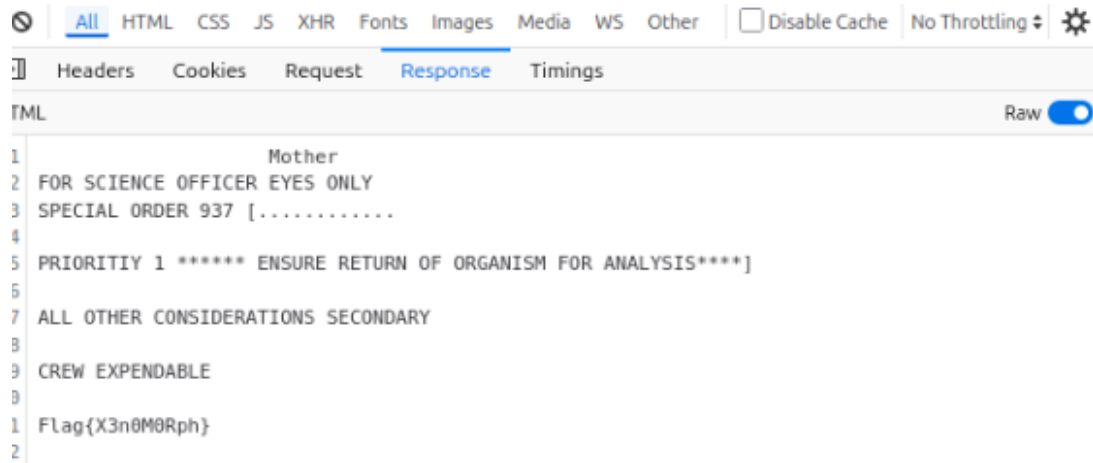
- Method: **POST**
- Endpoint: **/api/nostromo**
- Header: **Content-Type: application/json**

Next, I obtained the value `0RD3R_937.txt` from the `.yaml` file and included it in the JSON request body. After sending the POST request with the required payload and headers, the application processed the request and returned the expected response.



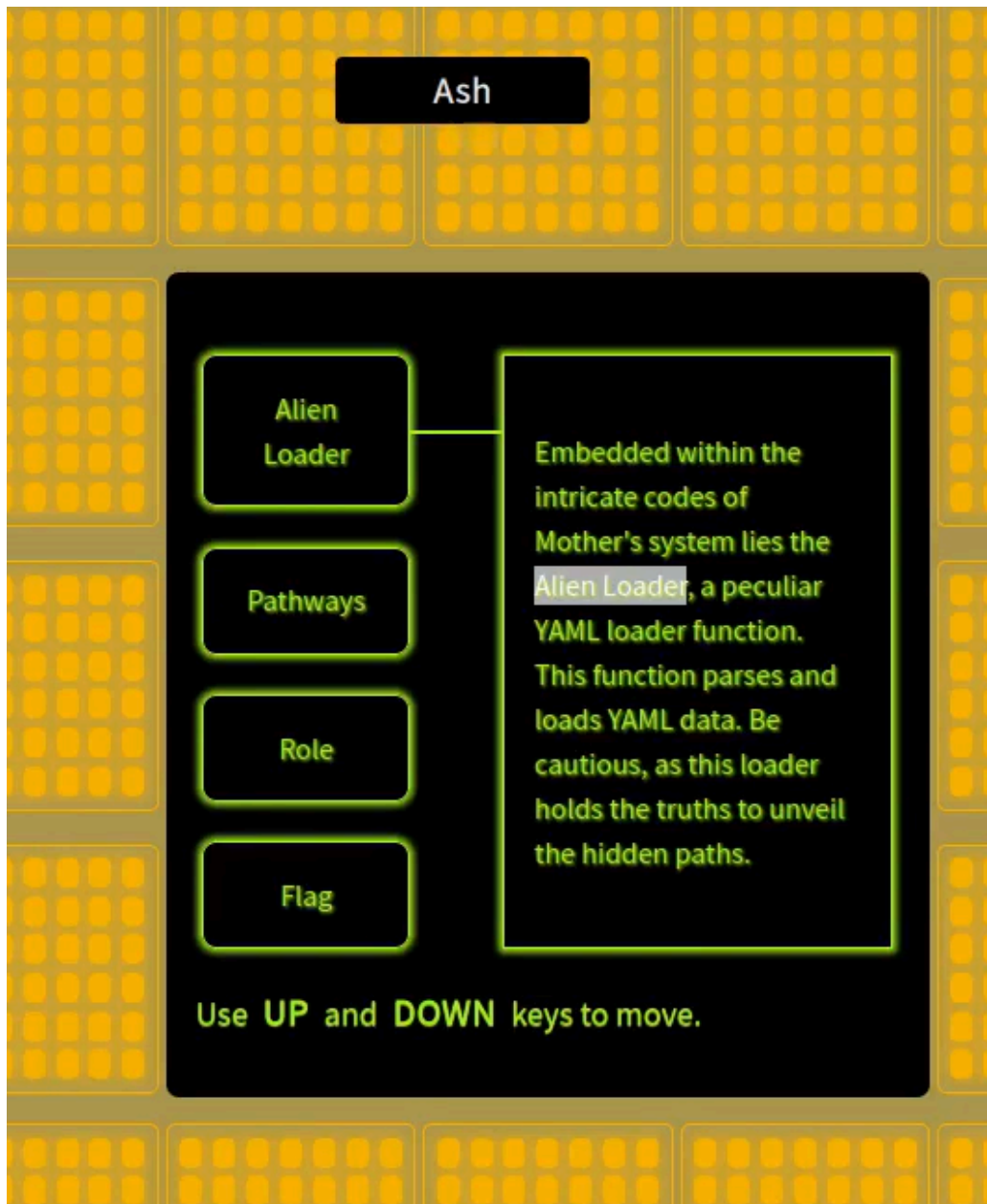
What is the hidden flag in the Nostromo route?

Flag{X3n0M0Rph}



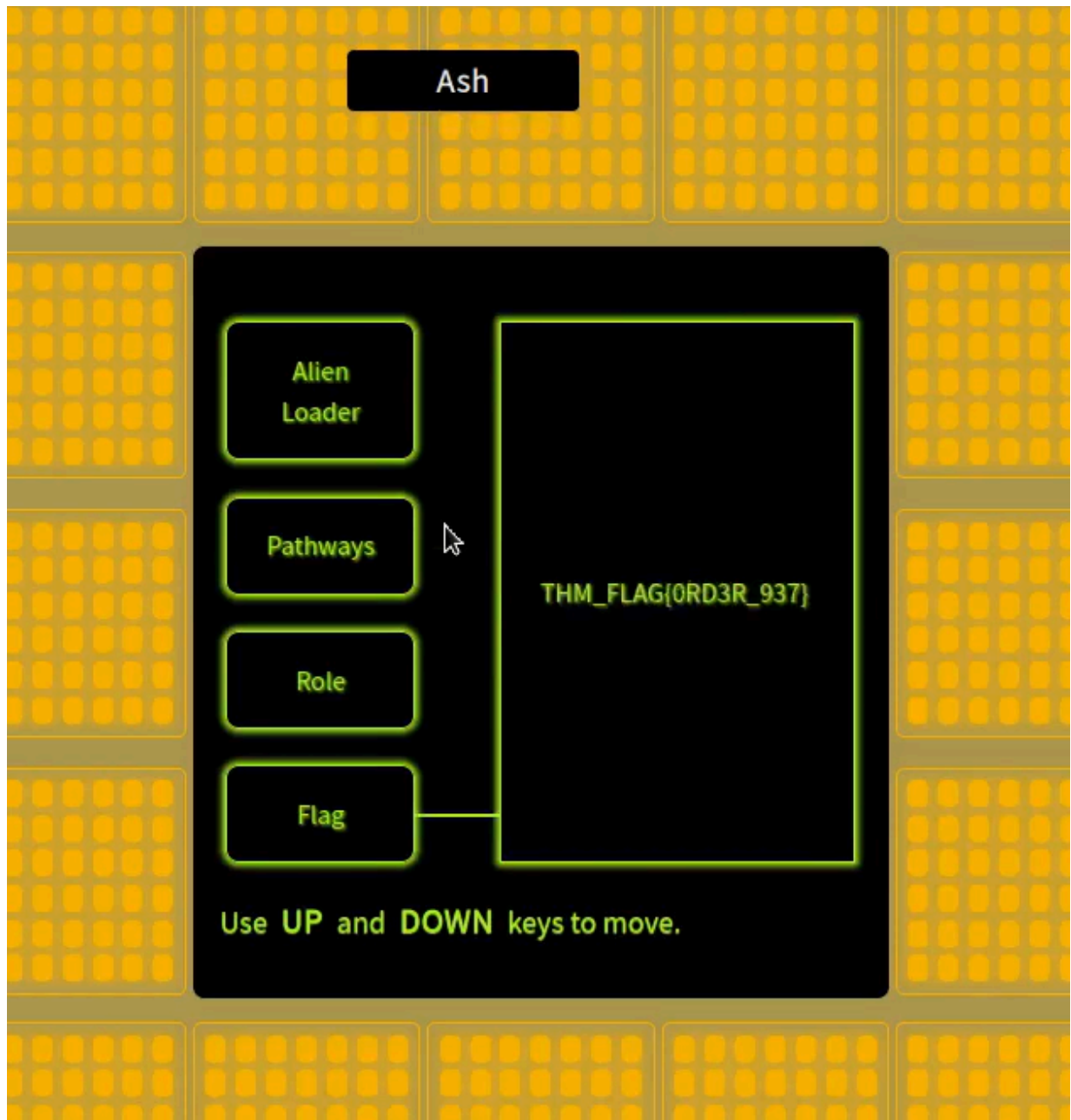
What is the name of the Science Officer with permissions?

Ash



What are the contents of the classified "Flag" box?

THM_FLAG{0RD3R_937}



| Where is Mother's secret?

/opt/m0th3r

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application									
Filter URLs									
New Request	Search	Blocking	St...	Method	Domain	File	Initiator	Ty...	Size
POST	http://10.113.191.186/api/nostro		394	GET	10.113.191.186	/	document	ht...	1.0...
URL Parameters									
☒ name	value		392	GET	cdn.tailwindcss.com	/	script	js ...	0 B
Headers									
☒ Host	10.113.191.186		200	GET	kit.fontawesome.com	4f572bc49d.js	script	js ...	6.1... 15...
☒ Accept-En	gzip, deflate		394	GET	cdn.socket.io	socket.io.min.js	script	js	cac... 0 B
☒ Connectio	keep-alive		394	GET	10.113.191.186	index.min.js	script	js	cac... 8.4...
☒ Upgrade	1		200	GET	fonts.googleapis.com	css2?family=Source+Sans+Pro&family=Ubuntu	stylesheet	css	cac... -1 B
☒ User-Age	Mozilla/5.0 (X11; Linux x86_64		200	GET	cdn.tailwindcss.com	3.4.17	script	js	cac... 407...
☒ Accept	text/html,application/xhtml+xml		200	GET	ka-f.fontawesome.com	free.min.css?token=4f572bc49d	4f572bc...	css	cac... 73...
☒ Accept-La	en-US,en;q=0.9		200	GET	ka-f.fontawesome.com	free-v4-shims.min.css?token=4f572bc49d	4f572bc...	css	cac... 21...
☒ Priority	u=0,i		200	GET	ka-f.fontawesome.com	free-v5-font-face.min.css?token=4f572bc49d	4f572bc...	css	cac... 823 B
☒ Content-T	application/json		200	GET	ka-f.fontawesome.com	free-v4-font-face.min.css?token=4f572bc49d	4f572bc...	css	cac... 1.7...
☒ name	value		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	pl...	28... 118 B
Body									
["file_path":"secret.txt"]									
200	POST		200	POST	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	ht...	14... 2 B
500	GET		500	GET	10.113.191.186	favicon.ico	img	json	cac... 42 B
200	GET		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	pl...	20... 38 B
200	POST		200	POST	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	ht...	14... 2 B
200	GET		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	pl...	20... 38 B
103	GET		103	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	pl...	12... 0 B
200	POST		200	POST	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	ht...	14... 2 B
103	GET		103	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	pl...	12... 0 B
200	GET		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	pl...	20... 42 B
200	GET		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	pl...	16... 1 B
200	GET		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	pl...	16... 1 B
200	POST		200	POST	10.113.191.186	yaml	xhr	ht...	39... 145 B
500	POST		500	POST	10.113.191.186	nostro	xhr	json	33... 56 B
200	POST		200	POST	10.113.191.186	nostro	xhr	ht...	48... 235 B
200	POST		200	POST	10.113.191.186	mother	xhr	ht...	27... 20 B

What is Mother's secret?

Flag{Ensure_return_of_organism_meow_meow!}

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application									
Filter URLs									
New Request	Search	Blocking	St...	Method	Domain	File	Initiator	Ty...	Size
POST	http://10.113.191.186/api/nostro		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	pl...	28... 118 B
URL Parameters									
☒ name	value		500	GET	10.113.191.186	favicon.ico	img	json	cac... 42 B
Headers									
☒ Host	10.113.191.186		200	POST	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	pl...	20... 38 B
☒ Accept-En	gzip, deflate		200	POST	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	ht...	14... 2 B
☒ Connectio	keep-alive		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	pl...	20... 38 B
☒ Upgrade	1		103	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	pl...	12... 0 B
☒ User-Age	Mozilla/5.0 (X11; Linux x86_64		200	POST	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	ht...	14... 2 B
☒ Accept	text/html,application/xhtml+xml		103	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	pl...	12... 0 B
☒ Accept-La	en-US,en;q=0.9		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	pl...	20... 42 B
☒ Priority	u=0,i		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	pl...	16... 1 B
☒ Content-T	application/json		200	GET	10.113.191.186	/socket.io/?EIO=4&transport=polling&PyNXPhQ	socket.io...	pl...	16... 1 B
☒ name	value		200	POST	10.113.191.186	yaml	xhr	ht...	39... 145 B
Body									
["file_path":"../../../../opt/moth3r"]									
500	POST		500	POST	10.113.191.186	nostro	xhr	json	33... 56 B
200	POST		200	POST	10.113.191.186	nostro	xhr	ht...	48... 235 B
200	POST		200	POST	10.113.191.186	mother	xhr	ht...	27... 20 B